

MCCoE CYBERSECURITY APPRENTICESHIP PROGRAM
PROJECT 2 OF 8 — PART 2: FRAMEWORKS + EXECUTIVE SUMMARY
TARGET DATA BREACH (2013)

Third-Party Vendor Attack · POS Malware · 40 Million Cards Stolen

THIS PROJECT: Apply the NIST CSF and pentesting methodology. Write and present your professional Executive Summary. This project ends with your Executive Summary submission (100 points).

PROJECT 2 · DAY 6	MONDAY — NIST CSF — DEFENSIVE FAILURE ANALYSIS	1-2 HRS
-------------------	--	---------

OBJECTIVE: Students apply all 5 NIST Cybersecurity Framework functions to identify exactly what the organization did wrong and what they should have done.

CLASS SCHEDULE

TIME	ACTIVITY	DETAIL / INSTRUCTIONS
0:00-0:20	Project Launch + Review	Quick recap of last project findings. Preview this project: today = defender perspective. What failed? What should have existed?
0:20-0:50	Lecture: NIST CSF	Teach the 5 functions. Draw a timeline on the board — overlay NIST. Show: Identify/Protect are BEFORE. Detect/Respond/Recover are DURING and AFTER.
0:50-1:40	NIST Failure Analysis	Students fill out the NIST table: for each function — specific failure + specific corrective action. No vague answers.
1:40-2:00	Critical Failure Vote	Which NIST function had the most catastrophic failure? Students vote and justify their answer. Discuss.

🎯 **OBJECTIVE:** Students map the attacker's actions to the 5 pentesting phases. Think like an attacker to become a better defender.

CLASS SCHEDULE

TIME	ACTIVITY	DETAIL / INSTRUCTIONS
0:00-0:30	Lecture: 5 Pentest Phases	Teach Reconnaissance, Scanning, Gaining Access, Maintaining Access, Covering Tracks. Why thinking like an attacker makes you a better defender.
0:30-1:10	Methodology Mapping	Students map the attacker's specific actions in this incident to each of the 5 phases. Include specific tools or techniques used.
1:10-1:40	Attacker vs Defender Game	For each phase: students suggest what the attacker did AND what a defender could have done to detect or stop it.
1:40-2:00	Homework Briefing	Assign: Tonight, outline your full Executive Summary using the template. Every section must have at least 3 bullet points before you write.

🎯 **OBJECTIVE:** Students develop and workshop 5 specific, actionable recommendations. Peer collaboration to pressure-test each recommendation.

CLASS SCHEDULE

TIME	ACTIVITY	DETAIL / INSTRUCTIONS
0:00-0:20	From Here On Out Review	Go through the "From Here On Out" section together. Discuss: are these the right priorities? Would you add anything?
0:20-1:00	Recommendations Workshop	Students draft their 5 recommendations with justification. Then pair up: each partner challenges one recommendation — is it specific enough? Does it address this incident?
1:00-1:30	Priority Debate	Class votes on the single most important recommendation. Each student defends their #1. Group builds a consensus top 5.
1:30-2:00	Executive Summary Drafting	

🎯 **OBJECTIVE:** Students complete peer review, deliver professional executive summary presentations, submit, and debrief the full incident.

CLASS SCHEDULE

TIME	ACTIVITY	DETAIL / INSTRUCTIONS
0:00-0:30	Writing + Peer Review	Students finalize all 9 sections of the Executive Summary. Swap with a partner: (1) strongest section, (2) one section needing more specifics, (3) one fact missed.
0:30-1:00	Revision Time	
1:00-1:45	Presentations + Submission	Each student presents 3-5 minutes. Collect completed Executive Summaries (100 pts). Class gives structured feedback: one strength, one specific improvement.
1:45-2:00	Full Debrief + Next Project Preview	What is the single most important lesson from this incident? What would you tell an IT team to do first thing Monday morning? Preview the next project.

NIST CSF FAILURE ANALYSIS REFERENCE

NIST FUNCTION	WHAT FAILED	WHAT SHOULD HAVE HAPPENED
Identify	FAILED — Did not assess third-party vendor risk; Fazio had broad network access with no vetting	Conduct regular asset inventories, vendor risk assessments, and map all third-party connections
Protect	FAILED — No network segmentation between vendor portal and payment systems; POS not isolated	Implement NIST SP 800-53 controls. Enforce MFA, patching SLAs, network segmentation
Detect	FAILED — FireEye alerts fired and were IGNORED; security team dismissed them as false positives	Deploy SIEM, IDS/IPS, behavioral analytics. Set up 24/7 monitoring with mandatory alert response SLAs
Respond	FAILED — 19 days passed before any action; no mandatory alert response policy existed	Develop and TEST an incident response plan. Establish clear escalation paths
Recover	PARTIAL — Cards replaced, settlements paid, new CISO hired, network redesigned post-breach	Implement and test backup/recovery. Define RTO and RPO. Conduct tabletop exercises regularly

ATTACKER METHODOLOGY — 5 PHASES REFERENCE

PHASE	WHAT THE ATTACKER DID IN THIS INCIDENT
Reconnaissance	Researched Target's vendor ecosystem publicly; identified Fazio as viable low-security entry point
Scanning	After vendor access, scanned Target's internal network to locate payment infrastructure
Gaining Access	Exploited trust relationship — vendor portal had direct path to internal payment network
Maintaining Access	BlackPOS malware deployed with persistence; blended with normal POS traffic patterns
Covering Tracks	Staged data on internal FTP before exfiltrating in batches to avoid volume-based alerts

"FROM HERE ON OUT" — RECOMMENDATIONS REFERENCE

🔗 **NOTE:** These are the controls that, if in place, would have prevented or significantly reduced this breach.

- **MANDATE:** Vendor risk management — require all third-party vendors to meet minimum security standards
- **MANDATE:** Network segmentation — isolate POS systems completely from corporate and vendor networks
- **MANDATE:** Alert response SLA — every high-severity alert gets human review within 15 minutes, no exceptions
- **IMPLEMENT:** Principle of least privilege — vendors access only what they need, nothing more
- **IMPLEMENT:** File integrity monitoring on all POS terminals
- **IMPLEMENT:** Chip-and-PIN (EMV) card technology — reduces value of stolen card data

REFERENCES & RESOURCES

- U.S. Senate Commerce Committee: "A Kill Chain Analysis of the 2013 Target Data Breach" (2014)
- Krebs on Security: "Target Hackers Broke in Via HVAC Company" — krebsonsecurity.com
- CISA Alert AA18-336A: Point-of-Sale Malware — cisa.gov
- MITRE ATT&CK: attack.mitre.org — search T1566, T1078, T1041
- NIST Cybersecurity Framework: nist.gov/cyberframework
- PCI Security Standards: pcisecuritystandards.org